

Consent Manager Feature Audit

Repository audit (read-only) · ConsentFlow / consent-manager
Generated: 4 September 2026 · Scope: routes, components, APIs, Drizzle schemas, SDK, auth/RBAC
NO CODE CHANGES **AUDIT ONLY**

Overall completion: ~58% of a full commercial CMP surface. Core consent loop (SDK → store → analytics/logs) is strong; reporting, enterprise RBAC, and vendor OAuth integrations are the main gaps.

1. Executive Summary

Metric	Estimate
Overall completion	~58%
Fully implemented (E2E) major areas	~9
Partial areas	~12
UI-only / stub	~4
Missing product areas	~8

Biggest strengths

- Real multi-tenant model (`organizationId` / website ownership) with Clerk + local org/membership bootstrap.
- Live JS SDK (`/api/sdk/script`, `/api/sdk/[siteKey]/config`) with banner + preference center and `/api/consent/record`.
- Consent records / decisions / events, cryptographic evidence, DB-backed analytics.
- Banner Studio persists into policy version `configuration` and feeds the SDK.
- HTML scanner (not mocked), scheduled scans via cron, drift/risk/quality from real findings.
- Developer primitives: hashed API keys at rest, webhooks with delivery attempts.

Biggest gaps

- No product report exports (CSV/PDF/Excel) or scheduled report delivery.
- RBAC permissions table is display-only; most APIs allow any org member.
- Integrations catalog = local DB association, not OAuth/vendor APIs (GCM/IAB signals are more real).
- API keys are created but not used to authenticate API calls.
- DSAR: intake + status + erasure automation; no access data package / portability / CCPA-style opt-out suite.
- Overview lacks consent rate card, date-range UI, exports, and quick-action hub.
- Script enforcement depends on `data-cmp-purpose` tagging; cookies/untagged third parties not fully blocked.

2. Module Score

Module	Score	Rationale
Dashboard / Overview	68%	Real metrics & charts; no date UI, exports, quick actions, DSAR widget
Websites	72%	Strong CRUD+verify+install+regs; no delete; verify optional for SDK
Cookie / Tracker Management	62%	Real scan→inventory→purpose map; weak cookie lifecycle/history
Consent Categories (Purposes)	70%	Create/list/required/associations; weak edit/delete/ordering
Consent Banner	82%	Studio → DB → SDK real; custom HTML/logo polish incomplete
Preference Center	76%	Live prefs + withdraw; enforcement incomplete for untagged assets
Consent Logs	86%	Strong auditability + proof; export/pagination gaps
Cookie Scanner	68%	Real HTML scanner + schedule + drift; not full browser crawl
Data Discovery	38%	Graph/data-flow only; no PII inventory product
Analytics	78%	Broad real aggregations + filters
Reports	8%	Effectively absent as a product
Privacy / DSAR	52%	Intake+workflow+erasure; missing access package & CCPA suite
Vendors	68%	Solid inventory; risk/automation partial
Compliance	42%	Geo/config + quality/risk ≠ certified compliance
Integrations	38%	GCM/IAB useful; catalog stub
Developer Platform	60%	SDK+webhooks strong; keys unused; no mobile SDKs
Notifications & Alerts	55%	In-app OK; no email channel
Team & RBAC	35%	Invite works; fine-grained RBAC not enforced
Organization Management	50%	Profile/retention; billing schema dormant
Settings	48%	Org/team/retention; security/SSO left to Clerk
Multi-tenancy / Security	70%	Solid org scoping; Owner bootstrap + unused permissions + API keys

3. Feature Matrix (condensed)

Statuses: **FULL** · **PARTIAL** · **UI ONLY** · **MISSING**

Module	Feature	Status	Evidence
Overview	Total / Active / Pending / Withdrawn	FULL	<code>src/app/dashboard/page.tsx</code> → <code>consent_records</code>
Overview	Trends (30d) + purpose donut	FULL	<code>src/lib/analytics/queries.ts</code>
Overview	Date range / export / quick actions	MISSING	Home hardcodes <code>days: "30"</code> ; no CSV/PDF
Websites	Add / list / edit / org association	FULL	<code>/dashboard/websites*</code> , <code>/api/websites*</code>
Websites	Domain verification	PARTIAL	Real checks; does not gate SDK
Websites	Delete website	MISSING	No DELETE on <code>/api/websites/[id]</code>
Trackers	Scan discovery + inventory	FULL	<code>scan-engine.ts</code> , <code>html-analyser.ts</code> , <code>trackers</code>

Module	Feature	Status	Evidence
Trackers	Fixed Necessary/Prefs/... taxonomy	PARTIAL	Free-form purposes , not fixed 7 categories
Purposes	Create / list / required / associations	FULL	/api/purposes , policy panels
Purposes	Edit / delete APIs	MISSING	Only POST under purposes API
Banner	Studio → DB → live SDK	FULL	Banner Studio + banner-config + SDK
Preference center	Toggles / save / withdraw	FULL	SDK + preview + consent APIs
Preference center	Affects all tracking	PARTIAL	Tagged scripts only (data-cmp-purpose)
Consent logs	List / detail / crypto proof	FULL	/dashboard/consent* , evidence API
Consent logs	CSV/JSON export UI	MISSING	Footer points to API only
Scanner	Manual + scheduled scans	FULL	Cron /api/cron/scans , schedules table
Scanner	Full browser / SPA crawl	PARTIAL	HTML fetch analyser, no headless browser
Analytics	Rates, geo, device, browser, purpose, site	FULL	loadConsentAnalytics , analytics page
Reports	PDF/CSV/Excel/scheduled email	MISSING	No export generators found
DSAR	Intake + status + admin + erasure	FULL	data_principal_requests + rights APIs
DSAR	Access package / portability / CCPA opt-out	MISSING	DPDP-oriented types; no access export
Compliance	Geo regs / quality / risk	PARTIAL	Product scores, not legal attestation
Integrations	GCM / IAB signals	PARTIAL	consent-integrations.ts
Integrations	GA/Meta/HubSpot OAuth	UI ONLY	Connect writes empty configuration
Developer	JS SDK + webhooks	FULL	SDK routes + webhook delivery
Developer	API key request auth	PARTIAL	Keys hashed but unused for auth
Notifications	In-app list/read	FULL	notifications table + APIs
Notifications	Email alerts	MISSING	In-app only
RBAC	Invite / Owner-Admin role ops	PARTIAL	Team APIs role-gated
RBAC	Permission key enforcement	UI ONLY	No requirePermission
Billing	Subscription product	UI ONLY	Schema exists; nav duplicates org settings
Security	Org isolation on APIs	FULL	Org filters + tenant website helpers

4. Implemented Features (working E2E)

- Auth + org workspace (Clerk, bootstrap, dashboard gate).
- Websites: create/list/detail/settings, environments field, domain verification, jurisdiction rules, scan schedule, installation snippet.
- Purposes & vendors: create/list, policy associations.
- Policies: version, publish, Banner Studio, preference preview writing real consent.
- Live SDK: banner, preference center, consent record/withdraw, Consent Mode / IAB signals when configured.
- Consent logs + cryptographic evidence API.

- Analytics with filters from DB aggregates.
- Scanner (HTML) + scheduled scans + drift/risk/quality + intelligence previews on live graph.
- Portable consent export/import.
- Rights requests intake/status/processing + erasure path.
- API key storage, webhooks + deliveries, in-app notifications, audit logs, team invite/role/remove.

5. Partially Implemented

Area	Exists	Missing / incomplete
Overview	Counts, trends, purpose donut, recent, checklist	Consent rate KPI, accept/reject cards, by-website, DSAR feed, date picker, exports, quick actions
Domain verification	Real TXT/meta/well-known	Does not block unverified sites from SDK
Environments	Stored labels	No separate runtime isolation
Trackers/cookies	Scan → inventory → purpose map	Rich cookie CMS, history, approve queue
Purposes	Create + required + associations	Edit/delete APIs; ordering UX
Enforcement	Tagged script pause/restore	Cookies / untagged third parties
Consent logs	Storage + evidence	CSV export UI; full pagination
Scanner	Fetch + signatures + schedule	Headless SPA crawl
DSAR	Intake, SLA fields, erasure	Access package, correction apply, portability, restrict, CCPA opt-out
Compliance	Regulations + quality/risk	True compliance engine / attestations
Integrations	Connect row + GCM/IAB	Provider OAuth
API keys	Create/hash/revoke UI	Authenticate requests
RBAC	Roles + permission catalog UI	Enforce keys on product APIs
Billing	DB tables	Product UI / metering
AI Autopilot	Assisted recommendations	No auto-publishing (explicit in code)

6. UI-Only / Stub Features

- **Integrations catalog Connect** — empty `configuration`; no OAuth.
- **Sidebar Billing** — navigates to Organization Settings; billing schemas unused.
- **Sidebar SDK / Installation** — points to API Keys, not website installation.
- **Permissions matrix** — display only; not checked in handlers.
- **Firewall scenarios** — preview simulator on real graph (not a fake table, but not a live appliance).
- Overview date locked to 30 days (real data, non-functional filter).

Core consent/analytics/scanner pages were **not** found to use mock visitor tables.

7. Missing Features (Prioritized)

P0 — Critical

- Enforce fine-grained RBAC (or document all members as operators).
- Fix membership bootstrap so non-owners are not minted as Owner.
- API key authentication for machine APIs *or* remove misleading API Keys claim.
- Consent/log export (CSV/JSON) for audits.
- Website delete (or soft-delete) with cascading safety.

P1 — High

- Report center (CSV first; PDF later); DSAR access package; purpose/vendor edit-delete; email alerts; domain-verify gating; stronger enforcement + docs.

P2 — Medium

- Overview quick actions + date-range + consent rate; cookie classify/history; preference history / re-consent UX; real integrations or shrink catalog; pagination.

P3 — Nice to have

- React/Next packages; mobile SDKs; scheduled email reports; Excel; headless scanner; SSO/SCIM UI; billing productization.

8. Security Gaps

Risk	Note
Fine-grained RBAC not enforced	Any active member can mutate most product APIs
Owner bootstrap for missing membership	<code>bootstrap-current-context</code> can assign Owner
API keys unused for auth	Hashed secrets without request verification
Consent proof secret default	Dev fallback if env unset — prod misconfig risk
Rate limits process-local	In-memory Map — weak under multi-instance
Domain verification optional	Unverified domains still get SDK config
Selective audit logging	Not all mutations audited
Policies/scans lack direct organizationId	Isolation via website join — IDOR if a route forgets the join

Positives: Clerk session on dashboard; org filters common; SSRF guards on scanner; CSRF origin checks; tenant website helper; rights erasure audited.

9. Data Model Gaps

Present & used: organizations, users, memberships, roles/permissions (underused), websites, jurisdiction rules, policies/versions, purposes, vendors, trackers, consent records/decisions/events, scans/results/schedules, privacy findings, DSAR requests, integrations + website links, API keys, webhooks, notifications, audit logs, billing tables (unused).

Missing / insufficient: dedicated cookies entity + change log; reports/report_runs; email outbox; DSAR artifacts; API key scopes + last-used + auth binding; permission enforcement helpers; billing usage wired to limits.

Stack note: 34 Drizzle schema files · 66 API routes · 0 server actions · 1 cron entry (`/api/cron/scans`).

10. Navigation Recommendation

1. **Home** — /dashboard
2. **Properties** — Websites (+ install, regulations, enforcement as site tabs)
3. **Consent** — Policies, Purposes, Vendors, Trackers, Consent logs
4. **Discovery** — Scanner, Privacy drift, Risk, Quality
5. **Insights** — Analytics, Experiments, Graph, Firewall, Simulator, Recommendations, Data flow (fold Autopilot/Twin/ROI/Negotiation under Labs)
6. **Privacy ops** — Rights requests, Audit logs, Notifications
7. **Developers** — API keys, Webhooks, SDK install deep-link, Integrations
8. **Admin** — Organization, Team & roles, Retention/security, Billing (when real)

11. Implementation Roadmap

1. **Phase 1 — Critical foundation:** RBAC baseline; Owner bootstrap fix; website delete; API key auth or UI honesty; consent CSV export; audit coverage; secret hardening.
2. **Phase 2 — Core Consent Management:** Purpose/vendor edit-delete; cookie classify workflow; enforcement hardening; domain-verify policy; overview date filter + quick actions + consent rate.
3. **Phase 3 — Analytics & Reporting:** Report builder (CSV→PDF); consent/cookie/scan/DSAR reports; scheduled exports; pagination.
4. **Phase 4 — Privacy / DSAR:** Identity verification; access package; correction apply; portability; CCPA opt-out/restrict; SLA email nudges.
5. **Phase 5 — Compliance:** Regulation packs tied to real controls; geo banner tests; compliance report from control evidence.
6. **Phase 6 — Developer / API:** Documented public API with key scopes; Next helper package; webhook catalog polish; sandbox keys.
7. **Phase 7 — Enterprise:** SSO/SCIM; website-level roles; billing/usage limits; email alert center; headless scanner; vendor OAuth.

12. Route Audit (discovered)

Route	Purpose	Status	Backend/DB
/dashboard	Overview	PARTIAL completeness	Real DB
/dashboard/websites*	Sites CRUD / install / enforcement / regs	Strong	Real
/dashboard/consent*	Logs + evidence	Strong	Real
/dashboard/policies*	Policies, studio, preference preview	Strong	Real

Route	Purpose	Status	Backend/DB
/dashboard/purposes*, /vendors*, /trackers	Catalogs	Strong (edit gaps)	Real
/dashboard/scanner*	Scans	Strong MVP	Real
/dashboard/analytics	Analytics	Strong	Real
/dashboard/monitoring*, /risk, /quality	Drift / risk / quality	Strong computed	Real
/dashboard/firewall ... /data-redaction	Intelligence suite	Advanced MVP	Real inputs
/dashboard/rights-requests	DSAR ops	Partial	Real
/dashboard/integrations	Catalog	Stub connect	DB stub
/dashboard/developers*	Keys / webhooks	Partial keys	Real storage
/dashboard/notifications, /audit-logs	Ops	Strong	Real
/dashboard/settings/organization, /team	Admin	Partial	Real

READY FOR IMPLEMENTATION — This document is an audit-only snapshot. No repository files were modified to produce the findings;
this PDF is a generated deliverable of the audit report for sharing and planning.